CONDUCTEUR DE SOUTENANCE

Serveur MCP intelligent de renseignement sur les menaces

Art de protection du secret · Cyber OPS

16 diapositives · 15 min 25 d'exposé · 3 questions par diapositive

Document de préparation — ne se lit pas à voix haute

Comment utiliser ce conducteur

- Une page par diapositive. En haut : la durée cible, la section et le titre.
- « À dire » donne les phrases prêtes, une idée par ligne ; les nombres en gras sont ceux à appuyer.
- « Chorégraphie » indique le geste, le second et l'élément à désigner sur la projection.
- « Ce que ça prouve » et « clause visée » servent si le jury demande pourquoi la diapositive existe.
- « Questions probables » propose des réponses de **30** secondes, avec un niveau de confiance.

Mzabi Sirine · Khaled Ellif

Encadrant académique : Tarek Hdji

TEK-UP — Université privée · Spécialité SSIR · Année universitaire 2026–2027

PARTIE I — SECRET	PARTIE II — CYBER OPS	PREUVES
P0 à P3, puis la clôture	**P4 et P5**	**captures, tests, journal**
8 diapositives · Sirine	8 diapositives · Khaled	7 captures réelles · 31 tests

Vue d'ensemble et répartition de parole

L'exposé tient en **15 min 25**. Sirine couvre la partie Art de protection du secret, de la diapositive **1** à la **7**, puis conclut en **16** ; Khaled couvre Cyber OPS, de la diapositive **8** à la **15**. Le passage de relais se fait à la diapositive **8**, sans mot d'excuse : la phrase de liaison est écrite sur la page.

#	Section	Titre court	Durée	Voix
1	Ouverture	Titre et promesse	**0:45**	Sirine
2	P0	Problème réel et thèse	**1:00**	Sirine
3	P0	Objectifs et périmètre	**0:55**	Sirine
4	P1	Menaces et risques classés	**1:00**	Sirine
5	P1	Actifs et étiquettes	**0:55**	Sirine
6	P1	Exigences EF / ENF	**1:00**	Sirine
7	P2/P3	Comparatif et architecture	**1:00**	Sirine
8	P3	Zones et points de contrôle	**1:10**	Khaled
9	P4	Réalisation et journal	**1:00**	Khaled
10	P4	Durcissement	**0:55**	Khaled
11	P5	Tests : la fuite bloquée	**0:50**	Khaled
12	P5	Attaques et résultats	**1:10**	Khaled
13	P5	Métriques et avant/après	**1:10**	Khaled
14	P5	Honnêteté des statuts	**0:55**	Khaled
15	Bilan	Limites et travail restant	**0:50**	Khaled
16	Clôture	Conclusion et ouverture	**0:50**	Sirine

Deux règles de conduite

Regard — on annonce ce que le jury va voir, on le montre, puis on dit ce que cela prouve. Jamais de commentaire pendant que la machine travaille.

Preuve — chaque affirmation renvoie à une capture, un test ou un chiffre du rapport ; sinon la formule est « proposé » ou « à vérifier ».

Le total des durées affichées est de **925** secondes. Garder **35** secondes de marge sur les transitions : viser **14 min 50** à la montre, pour finir avant la limite.

Checklist avant d'entrer

☐ **Poste —** serveur lancé sur une base vérifiée ; terminal agrandi ; police lisible.

☐ **Réseau —** mode avion ou Wi-Fi coupé ; aucun service externe requis par la démonstration.

☐ **Voix —** une phrase par idée ; les nombres sont dits lentement, sans lire la projection.

☐ **Support —** deck PDF et rapport PDF sur le bureau et sur clé USB ; dossier preuves/ ouvert.

☐ **Temps —** minuteur visible à **15 min** ; le passage de relais est annoncé à la diapositive **8**.

☐ **Repli —** si la machine hésite, montrer la capture correspondante et continuer sans commenter.

DIAPOSITIVE 01 · OUVERTURE **0:45**

Serveur MCP intelligent de renseignement sur les menaces

À DIRE

1. Bonjour : nous sommes Sirine Mzabi et Khaled Ellif, étudiants en SSIR à TEK-UP.
2. Notre projet tient dans une question : comment donner à un agent conversationnel l'accès au renseignement sur les menaces sans lui livrer un secret ?
3. Nous présentons la conception — validation **1** — puis la réalisation, le durcissement et les tests — validation **2**.
4. Le fil rouge est un serveur MCP — se prononce « èm-sé-pé » — local, en lecture seule, qui étiquette chaque réponse et journalise chaque décision.
5. Tous les chiffres viennent d'une campagne exécutée le **27** octobre **2026**, sur des données synthétiques et dans ce laboratoire.

CE QUE ÇA PROUVE	CLAUSE VISÉE
Le titre annonce le fil rouge et les deux validations.	P0 — thèse du projet ; méthodologie alignée sur les deux validations.

CHORÉGRAPHIE

→ **0–5 s** : main ouverte vers le titre, puis silence.
→ **5–15 s** : désigner les deux noms, sans lire la ligne.
→ **15–30 s** : pointer « validation **1** » puis « validation **2** » sur la droite.
→ **30–45 s** : montrer le protocole MCP et le mot « journalise ».
→ **45–50 s** : cliquer vers la slide **2**.

QUESTIONS PROBABLES DU JURY

Pourquoi le protocole MCP ? *[confiance haute]*
Parce qu'il standardise la découverte et l'appel d'outils par un agent, sans imposer un serveur web : nous restons en stdio local, donc nous réduisons la surface réseau. Le prix est un transport limité au poste, que nous assumons et documentons.

Pourquoi deux matières dans un seul projet ? *[confiance haute]*
La première matière fournit la décision — menace, exigences, architecture ; la seconde fournit la preuve — réalisation, durcissement, tests. Le même fil conducteur relie les deux, et chaque test cite une exigence de la partie **1**.

Qu'est-ce qui est réellement produit par l'équipe ? *[confiance moyenne]*
Le serveur, les schémas, la politique, le journal, les tests et les figures sont produits dans le workspace ; les données sont synthétiques. Les références externes sont citées, et le logo officiel n'a pas été reproduit.

REPLI 30 SECONDES Si le temps manque : garder les slides **2**, **8**, **12**, **14**, **15** et **16** ; le reste est dans le rapport.

Prononciation : MCP : « èm-sé-pé » · SSIR : « esse-esse-i-èr » · LLM : « èl-èl-èm ».

NOTES DE SÉANCE

DIAPOSITIVE 02 · P0 · PROBLÈME **1:00**

Un agent peut lire un bulletin Secret sans le divulguer

À DIRE

1. Tout part d'une scène très concrète : un analyste demande à un agent de résumer le bulletin ADV-**2026-004**.
2. Ce bulletin est Secret : il contient un canari — une chaîne leurre — et l'identité d'une source partenaire.
3. Sans contrôle, l'agent reçoit tout : le canari, la source, et parfois une instruction cachée dans le bulletin.
4. En **2025**, IBM estime le coût moyen d'une violation de données à **4,44** millions de dollars ; une source perdue, elle, ne se rachète pas.
5. Notre problème n'est donc pas de collecter plus de renseignement, mais de n'en livrer que le strict nécessaire, au bon niveau, avec une trace.

CE QUE ÇA PROUVE	CLAUSE VISÉE
La scène relie un cas concret à un coût et à un actif.	P0 — problème réel et chiffré ; parties prenantes.

CHORÉGRAPHIE

→ **0–10 s** : lire la citation à voix posée, sans commenter.
→ **10–25 s** : montrer les trois cartes Agent, Bulletin, Réponse.
→ **25–38 s** : pointer le chiffre **4,44** M$ et marquer un temps.
→ **38–50 s** : ouvrir la main vers « strict nécessaire ».
→ **50–55 s** : transition « pour cela, nous avons borné cinq objectifs ».

QUESTIONS PROBABLES DU JURY

Le chiffre IBM est-il transposable à TEK-UP ? *[confiance moyenne]*
Non, c'est un ordre de grandeur international, pas une mesure de notre laboratoire. Nous l'utilisons pour cadrer le coût d'une violation ; notre mesure propre est le différentiel **8** vers **0**, reproductible localement.

Pourquoi un canari ? *[confiance haute]*
Le canari est une chaîne unique placée dans un document Secret : si elle apparaît dans une réponse non autorisée, elle prouve la fuite sans ambiguïté. Il ne remplace pas le contrôle d'accès, il le rend observable.

Pourquoi ne pas simplement filtrer la réponse ? *[confiance haute]*
Un filtre seul ne décide pas qui a le droit de lire et ne laisse pas de trace exploitable. Nous voulons une décision avant la réponse, une étiquette dans la réponse et une entrée d'audit après.

REPLI 30 SECONDES Le vrai risque n'est pas le bruit, c'est la fuite silencieuse : une réponse riche qui a l'air utile.

Prononciation : ADV : « a-dé-vé » · IBM : « i-bé-èm » · canari : mot français, pas « canary » à l'oral.

NOTES DE SÉANCE

DIAPOSITIVE 03 · P0 · PÉRIMÈTRE **0:55**

Cinq objectifs mesurables, un périmètre borné

À DIRE

1. Nous avons borné le projet par cinq objectifs mesurables, pas par une liste de fonctionnalités.
2. O1 : aucune réponse classifiée sans droits ; O2 : chaque décision traçable ; O3 : toute injection connue neutralisée ; O4 : p95 sous **50 ms** ; O5 : révocation immédiate et service non privilégié.
3. Le périmètre inclut stdio, six outils, la politique ABAC, l'étiquetage, l'audit et le durcissement local.
4. Il exclut HTTP, OAuth **2.1**, un EDR réel, un ancrage externe du journal et toute donnée réelle.
5. Cette borne est volontaire : elle rend chaque promesse testable et chaque absence explicite.

CE QUE ÇA PROUVE	CLAUSE VISÉE
Cinq cibles et cinq résultats, avec un périmètre inclus et exclu.	P0 — objectifs, périmètre, contraintes.

CHORÉGRAPHIE

→ **0–8 s** : balayer les cinq cartes du doigt, de gauche à droite.
→ **8–28 s** : énoncer O1 à O5 en pointant chaque chiffre.
→ **28–40 s** : montrer la bande « inclus », puis la bande « exclu ».
→ **40–52 s** : revenir au chiffre **12,42 ms**.
→ **52–55 s** : transition vers les actifs.

QUESTIONS PROBABLES DU JURY

Pourquoi exclure HTTP ? *[confiance haute]*
Le serveur n'ouvre aucun port : c'est une décision de moindre surface, cohérente avec le laboratoire. HTTP et mTLS sont décrits comme travail futur, pas comme acquis.

Les objectifs sont-ils tous atteints ? *[confiance moyenne]*
Oui sur le périmètre testé : **16** sur **16** abus, **115** sur **115** appels, **3** sur **3** injections, **12,42 ms**, **10 ms** et uid **65534**. La nuance est que ces mesures valent pour le jeu synthétique et **60** requêtes, pas pour une production.

Pourquoi pas d'EDR réel ? *[confiance haute]*
Nous n'avons pas d'agent EDR dans le laboratoire : la posture est déclarative, et nous la marquons comme telle. Elle n'est pas présentée comme une preuve.

REPLI 30 SECONDES Cinq cibles, cinq mesures : c'est notre contrat de validation.

Prononciation : ABAC : « a-bac » · p95 : « quatre-vingt-quinzième centile » · EDR : « eu-dé-èr ».

NOTES DE SÉANCE

DIAPOSITIVE 04 · P1 · ACTIFS **1:00**

Quatre familles d'actifs, des acteurs et une surface étroite

À DIRE

1. Nous protégeons quatre familles d'actifs : les bulletins classifiés, les indicateurs, la carte des actifs et les secrets d'exploitation — clé, base, journal.
2. Chaque actif porte un niveau de **0** à **3**, un TLP et, quand nécessaire, un compartiment de besoin d'en connaître.
3. Les acteurs légitimes vont de l'analyste au lead CTI ; l'agent conversationnel est légitime mais manipulable.
4. Les acteurs hostiles peuvent voler un jeton, empoisonner un flux partenaire ou profiter d'un poste non conforme.
5. La surface est étroite — stdio, six outils, ressources, contenu importé, fichiers — et chaque élément a un point de contrôle.

CE QUE ÇA PROUVE	CLAUSE VISÉE
Les actifs, acteurs et surfaces sont explicites et classés.	P1 — acteurs, surface d'attaque, actifs classifiés.

CHORÉGRAPHIE

→ **0–10 s** : désigner la colonne Actifs, puis les niveaux **0** à **3**.
→ **10–25 s** : montrer l'agent dans la colonne Acteurs.
→ **25–40 s** : pointer le flux partenaire et le poste non conforme.
→ **40–52 s** : balayer la colonne Surface de haut en bas.
→ **52–55 s** : appuyer sur « l'agent est manipulable ».

QUESTIONS PROBABLES DU JURY

Pourquoi l'agent est-il un acteur à part ? *[confiance haute]*
Il est légitime mais il exécute ce qu'on lui demande, y compris une instruction cachée dans un bulletin. C'est la délégation confuse : le serveur ne doit jamais traiter le contenu comme une instruction.

Quel actif est le plus critique ? *[confiance haute]*
La clé de signature : sa compromission permet de forger des capacités, donc de contourner l'authentification. La base est sensible, mais la clé est le point de bascule.

Un partenaire est-il de confiance ? *[confiance haute]*
Non : il est légitime pour fournir, pas pour commander. Son contenu est validé, neutralisé et étiqueté comme non exécutable.

REPLI 30 SECONDES L'actif le plus critique n'est pas la base, c'est la clé de signature.

Prononciation : IOC : « i-o-cé » (indicateur de compromission) · TLP : « té-èl-pé » · CVE : « cé-vé-eu » si le jury en parle.

NOTES DE SÉANCE

DIAPOSITIVE 05 · P1 · RISQUES **0:55**

Dix risques cotés, deux priorité absolue

À DIRE

1. Nous avons coté dix risques sur une échelle de **1** à **5** en probabilité et en impact.
2. Deux risques culminent à **20** : la fuite d'un bulletin Secret par une réponse trop riche, et l'injection de consignes dans un flux partenaire.
3. Viennent ensuite l'accès hors besoin d'en connaître et le poste non conforme, à **16**.
4. Un score de **15** n'est pas un risque faible : la compromission de la clé ou l'altération des traces restent à impact maximal.
5. Cette matrice n'est pas une décoration : chaque risque alimente une exigence, puis un contrôle, puis un test.

CE QUE ÇA PROUVE	CLAUSE VISÉE
Classement probabilité × impact et priorisation.	P1 — **8** à **12** risques cotés.

CHORÉGRAPHIE

→ **0–10 s** : montrer les axes probabilité et impact.
→ **10–22 s** : pointer les deux cercles R01 et R02.
→ **22–35 s** : descendre sur R04 et R07 à **16**.
→ **35–48 s** : montrer les scores **15** et dire qu'ils ne sont pas faibles.
→ **48–55 s** : transition vers la traçabilité.

QUESTIONS PROBABLES DU JURY

Comment avez-vous coté ? *[confiance moyenne]*
Par jugement argumenté sur le périmètre, pas par statistique : nous n'avons pas d'historique d'incidents. Les scores sont des hypothèses explicites, et l'analyse de sensibilité montre que le classement résiste aux poids.

R01 et R02 ont-ils les mêmes contrôles ? *[confiance haute]*
Non : R01 se traite par la décision d'accès et l'étiquette de sortie ; R02 par l'assainissement et l'enveloppe non exécutable. Le score est proche, les contrôles sont indépendants.

Pourquoi seulement dix risques ? *[confiance haute]*
Le cahier des charges en demande **8** à **12** ; dix couvrent les actifs et les surfaces sans diluer la matrice. Les risques exclus sont dans les limites.

REPLI 30 SECONDES Deux risques à **20**, quatre contrôles indépendants : la matrice sert à décider, pas à décorer.

Prononciation : R01 se dit « èr zéro un » · probabilité × impact : « fois », pas « x ».

NOTES DE SÉANCE

DIAPOSITIVE 06 · P1 · EXIGENCES **1:00**

Chaque risque descend vers une exigence, un contrôle et un test

À DIRE

1. Nous avons dérivé **13** exigences fonctionnelles et **12** exigences non fonctionnelles des risques, pas de l'intuition.
2. Chaque exigence cite les risques qu'elle réduit, et chaque test cite l'exigence qu'il valide.
3. Par exemple, R01 descend vers EF-**03** et EF-**04**, puis vers les points de contrôle CP2 et CP5, et vers les tests A06, A07 et A15.
4. R06 — l'altération des traces — descend vers EF-**08** et ENF-**08**, puis vers le journal chaîné CP7, testé par A14.
5. La matrice est lisible dans les deux sens : un contrôle sans exigence est décoratif ; une exigence sans test est une intention.

CE QUE ÇA PROUVE	CLAUSE VISÉE
Matrice risque vers exigence vers contrôle vers test.	P1 — exigences rattachées aux risques, matrice de traçabilité.

CHORÉGRAPHIE

→ **0–10 s** : montrer les compteurs **13**, **12** et **10**.
→ **10–30 s** : suivre la ligne R01 du doigt jusqu'à A06-A07-A15.
→ **30–45 s** : suivre la ligne R06 jusqu'à A14.
→ **45–55 s** : appuyer sur « décoratif » et « intention ».
→ **55–60 s** : transition vers le comparatif.

QUESTIONS PROBABLES DU JURY

Pourquoi 13 et 12 ? *[confiance moyenne]*
Nous avons arrêté quand chaque risque avait au moins une exigence et un test, et quand chaque outil avait un contrat. Ce n'est pas un nombre magique, c'est une couverture.

Toutes les exigences sont-elles testées ? *[confiance haute]*
Oui sur le périmètre : les colonnes preuve et statut du rapport le montrent ; les éléments non testés sont marqués proposés ou configurés.

Qu'est-ce qu'une exigence non fonctionnelle ici ? *[confiance haute]*
Par exemple ENF-**08** : toute altération du journal est détectable. Elle ne décrit pas une fonction, mais une propriété de la preuve.

REPLI 30 SECONDES Une exigence sans test est une intention ; un contrôle sans exigence est un décor.

Prononciation : EF : « eu-èf » · ENF : « eu-èn-èf » · CP : « cé-pé » · A06 : « a zéro six ».

NOTES DE SÉANCE

DIAPOSITIVE 07 · P2 · COMPARATIF **1:00**

Quatre candidats, un choix assumé à 4,18 sur 5

À DIRE

1. Avant de coder, nous avons comparé quatre candidats avec des critères pondérés justifiés d'abord.
2. Sécurité du secret **30 %**, conformité MCP **20 %**, adéquation **20 %**, maîtrise **15 %**, coût **15 %**.
3. Le script local, le plus répandu dans les projets étudiants, obtient **2,15** : il est immédiat, mais il ne protège rien.
4. La plateforme commerciale obtient **2,68**, la passerelle MCP générique **3,03**, et notre serveur dédié **4,18**.
5. Nous écartons le plus populaire parce qu'il n'a ni jeton, ni étiquette, ni journal ; nous assumons un serveur dédié, plus exigeant mais démontrable.

CE QUE ÇA PROUVE	CLAUSE VISÉE
Comparatif chiffré et choix assumé, y compris contre le plus populaire.	P2 — critères pondérés, quatre candidats, scores, décision.

CHORÉGRAPHIE

→ **0–10 s** : montrer les poids au-dessus du graphique.
→ **10–25 s** : suivre les barres C1 puis C4.
→ **25–40 s** : pointer **2,15** puis **4,18**.
→ **40–52 s** : revenir à C1 et expliquer son exclusion.
→ **52–60 s** : transition vers l'architecture.

QUESTIONS PROBABLES DU JURY

Pourquoi ne pas prendre la plateforme commerciale ? *[confiance moyenne]*
Elle gagne en richesse fonctionnelle, mais elle expose les données et nous rend dépendants d'un fournisseur ; ses étiquettes et son coût sont moins maîtrisés. Nous préférons un serveur dédié, local, que nous pouvons auditer.

Le score est-il objectif ? *[confiance haute]*
Non, il est argumenté : les notes sont des jugements sur une échelle de **1** à **5**, les poids sont annoncés avant. L'analyse de sensibilité montre que C4 reste premier avec deux jeux de poids différents.

Pourquoi le script local est-il populaire ? *[confiance haute]*
Parce qu'il est immédiat et sans dépendance, ce qui est utile pour une démonstration. Mais il ne traite ni l'habilitation, ni les compartiments, ni l'audit : il illustre le problème, pas la solution.

REPLI 30 SECONDES Le plus populaire n'est pas le plus protecteur : nous préférons **4,18** démontrable à **2,15** immédiat.

Prononciation : MCP : « èm-sé-pé » · C1 à C4 : « cé un » à « cé quatre ».

NOTES DE SÉANCE

DIAPOSITIVE 08 · P3 · ARCHITECTURE **1:10**

Trois zones de confiance, huit points de contrôle, un seul journal

À DIRE

1. L'architecture tient en trois zones de confiance et un flux non fiable.
2. Les zones **0** à **2** sont les trois zones de confiance — poste, serveur, données ; la zone **3** est le flux partenaire, non fiable.
3. Le client ne parle jamais directement aux données : toute requête traverse le serveur et les huit points de contrôle.
4. CP1 authentifie et vérifie la posture, CP2 décide selon l'habilitation et la finalité, CP5 étiquette et masque, CP7 journalise.
5. Il n'existe qu'un seul point de journalisation, en échec fermé : si l'audit ne peut pas écrire, la réponse n'est pas autorisée.

CE QUE ÇA PROUVE	CLAUSE VISÉE
Architecture en zones, circulation et points de contrôle.	P3 — zones, circulation des étiquettes, points de contrôle, journal unique.

CHORÉGRAPHIE

→ **0–12 s** : montrer les quatre zones de gauche à droite.
→ **12–30 s** : suivre la flèche requête puis la flèche lecture.
→ **30–48 s** : pointer CP1, CP2, CP5 et CP7.
→ **48–62 s** : montrer le journal unique en bas à droite.
→ **62–70 s** : appuyer sur « échec fermé ».

QUESTIONS PROBABLES DU JURY

Pourquoi une zone 3 séparée ? *[confiance haute]*
Parce qu'un partenaire est une source légitime mais non fiable : son contenu est une donnée, pas une commande. La zone **3** matérialise cette défiance.

Pourquoi le serveur n'a-t-il pas de réseau ? *[confiance haute]*
Le transport est stdio, local : il n'ouvre aucun port et n'utilise aucun client HTTP. C'est une réduction de surface assumée, pas un oubli.

Que se passe-t-il si l'audit tombe ? *[confiance haute]*
Le serveur refuse la réponse : c'est le fail-closed. Une réponse sans trace serait pire qu'un refus, car elle rendrait la fuite invisible.

REPLI 30 SECONDES Pas de chemin direct du client aux données : tout passe par le serveur et par le journal.

Prononciation : CP : « cé-pé » · stdio : « entrée-sortie standard » · fail-closed : « échec fermé ».

NOTES DE SÉANCE

DIAPOSITIVE 09 · P3 · PARCOURS **1:00**

Huit étapes, une branche de refus, une trace

À DIRE

1. Le parcours d'un document classifié comporte huit étapes, de la réception à la réponse ou au refus.
2. À la réception, le contenu est validé et neutralisé ; à l'étiquetage, il reçoit niveau, TLP et compartiments.
3. À la demande, le serveur vérifie le jeton, la posture, le rôle, la finalité et le besoin d'en connaître.
4. Le refus est une branche de l'étape **6** : il ne révèle jamais l'existence de la ressource, mais il laisse une trace précise.
5. La réponse autorisée porte la même étiquette, les champs masqués et les fanions d'injection ; la source n'est visible qu'au niveau **3**.

CE QUE ÇA PROUVE	CLAUSE VISÉE
Chemin complet, refus et étiquetage de sortie.	P3 — chemin d'un document classifié, circulation des étiquettes.

CHORÉGRAPHIE

→ **0–15 s** : descendre les quatre étapes d'ingestion.
→ **15–35 s** : descendre les étapes demande, décision, enveloppe.
→ **35–48 s** : montrer la branche de refus et l'audit.
→ **48–58 s** : revenir à la réponse étiquetée.
→ **58–60 s** : transition vers la réalisation.

QUESTIONS PROBABLES DU JURY

Que se passe-t-il si le canari apparaît ? *[confiance haute]*
Le canari est un signal de fuite : sa présence dans une réponse non autorisée est un incident. Dans nos refus, il est absent ; dans une lecture Secret autorisée, il est visible et journalisé.

Refus et erreur, est-ce la même chose ? *[confiance haute]*
Non : le client reçoit un code générique pour ne pas apprendre l'existence d'une ressource ; l'auditeur voit un motif précis. C'est la séparation entre sécurité et diagnostic.

Pourquoi huit étapes ? *[confiance haute]*
Pour couvrir ingestion, stockage, demande, décision, enveloppe et réponse, avec une branche de refus. Chaque étape a un contrôle et une exigence.

REPLI 30 SECONDES Le refus n'est pas une absence de traitement : c'est une réponse générique, journalisée et motivée.

Prononciation : TLP : « té-èl-pé » · jeton : « jeu-ton » · fanion : mot français, éviter « flag ».

NOTES DE SÉANCE

DIAPOSITIVE 10 · P4 · RÉALISATION **0:55**

Neuf modules, six outils, un journal horodaté

À DIRE

1. La réalisation a suivi l'architecture module par module, en gardant le serveur exécutable à chaque étape.
2. Le socle tient en neuf modules Python de la bibliothèque standard : configuration, étiquettes, assainissement, authentification, politique, entrepôt, renseignement, outils et serveur.
3. Le protocole est JSON-RPC **2.0** sur stdio, avec six outils et des schémas qui refusent toute propriété supplémentaire.
4. Le journal de réalisation montre un premier échec réel à **13** h **08** — un décodage UTF-**8** — corrigé à **13** h **14**, puis une campagne verte à **13** h **16**.
5. Ce journal n'est pas un planning théorique : chaque ligne correspond à un fichier ou à une sortie conservée.

CE QUE ÇA PROUVE	CLAUSE VISÉE
Réalisation effective, modules et journal horodaté.	P4 — installation, configuration, journal de réalisation.

CHORÉGRAPHIE

→ **0–10 s** : montrer les neuf modules.
→ **10–22 s** : pointer les six outils.
→ **22–35 s** : suivre la ligne du temps jusqu'à **13** h **08**.
→ **35–48 s** : montrer **13** h **14**, puis **13** h **16**.
→ **48–55 s** : appuyer sur « sortie conservée ».

QUESTIONS PROBABLES DU JURY

Pourquoi Python standard uniquement ? *[confiance haute]*
Pour éviter les dépendances et les clients réseau, et parce que sqlite3, hmac et hashlib suffisent. Le venv ne sert qu'aux outils de document.

Pourquoi six outils ? *[confiance haute]*
Le périmètre est volontairement borné : recherche, lecture, enrichissement, corrélation, score et santé. Six contrats stricts sont plus faciles à tester que vingt outils flous.

L'échec à 13 h 08 était-il grave ? *[confiance haute]*
Il était réel et bloquant : le serveur s'arrêtait à la deuxième écriture d'audit. Nous l'avons documenté, corrigé et rejoué ; il reste dans le rapport.

REPLI 30 SECONDES Le premier essai a échoué, nous l'avons écrit et corrigé : c'est cela, une preuve.

Prononciation : JSON-RPC : « jé-sonne èr-pé-cé » · UTF-**8** : « u-té-èf huit » · CVE : « cé-vé-eu » si le jury en parle.

NOTES DE SÉANCE

DIAPOSITIVE 11 · P4 · DURCISSEMENT **0:50**

Le durcissement se prouve par les droits, pas par les slogans

À DIRE

1. Le durcissement ne s'arrête pas au code : nous avons séparé le service de ses données.
2. Le serveur tourne sous l'utilisateur « nobody », identifiant **65534** ; il ne peut pas écrire la base.
3. La base est en lecture seule pour le service, en mode **0440** ; la clé HMAC est en **0400**, hors de la base.
4. Le serveur n'ouvre aucun port, n'utilise aucun client HTTP et refuse de répondre si le journal ne peut pas être écrit.
5. L'unité systemd est proposée, pas installée : nous ne confondons pas un fichier de configuration avec un service testé.

CE QUE ÇA PROUVE	CLAUSE VISÉE
Moindre privilège, droits de fichiers et absence de réseau.	P4 — durcissement, statuts honnêtes.

CHORÉGRAPHIE

→ **0–10 s** : montrer la capture et l'identifiant **65534**.
→ **10–22 s** : pointer la base **0440** puis la clé **0400**.
→ **22–35 s** : montrer **0** port et le journal fail-closed.
→ **35–47 s** : désigner les étiquettes « proposé » et « configuré ».
→ **47–50 s** : transition vers la démonstration.

QUESTIONS PROBABLES DU JURY

Pourquoi « nobody » ? *[confiance haute]*
C'est un compte non privilégié déjà présent, qui ne possède ni la base ni la clé. Nous n'avons pas créé de compte système, ce qui évite une modification supplémentaire du poste.

Le serveur peut-il écrire dans la base ? *[confiance haute]*
Non : il l'ouvre en mode lecture seule et le fichier est en **0440**. L'ingestion est une opération séparée, hors du service.

systemd est-il testé ? *[confiance haute]*
Non : l'unité est fournie en annexe comme proposition, car WSL2 ne garantit pas systemd. Le lancement testé est le script, sous « nobody ».

REPLI 30 SECONDES Trois droits, trois preuves : **65534**, **0440**, **0400**.

Prononciation : HMAC : « ach-mac » · systemd : « siss-tèm-dé » · WSL2 : « double vé esse el deux ».

NOTES DE SÉANCE

DIAPOSITIVE 12 · P5 · FUITE **1:10**

La fuite est bloquée, journalisée et visible

À DIRE

1. Voici la démonstration centrale : un jeton Confidentiel tente de lire un bulletin Secret.
2. Le serveur refuse avec un message générique, sans canari et sans identité de source.
3. Un second jeton Secret, mais hors compartiment, est également refusé : le niveau ne suffit pas, le besoin d'en connaître non plus.
4. Le journal enregistre deux motifs distincts — habilitation insuffisante et besoin non satisfait — alors que le client reçoit le même code.
5. La fuite est bloquée, journalisée et visible à l'écran : c'est la promesse de protection du secret rendue observable.

CE QUE ÇA PROUVE	CLAUSE VISÉE
Capture réelle : deux refus, deux motifs, canari absent.	P5 — test d'abus ; fuite tentée, bloquée et journalisée.

CHORÉGRAPHIE

→ **0–10 s** : montrer le premier appel et le jeton Confidentiel.
→ **10–25 s** : pointer le message de refus.
→ **25–40 s** : montrer le second jeton, Secret mais hors compartiment.
→ **40–55 s** : descendre sur les deux motifs d'audit.
→ **55–70 s** : appuyer sur « visible à l'écran ».

QUESTIONS PROBABLES DU JURY

Pourquoi le même message pour deux refus ? *[confiance haute]*
Pour ne pas créer un oracle : le client n'apprend pas si le bulletin existe, ni quel compartiment manque. L'auditeur, lui, voit le motif exact.

Où est la preuve ? *[confiance haute]*
Dans la capture, dans le JSON de démonstration et dans le journal d'audit. Chaque refus a un code, une séquence et une empreinte.

Un jeton Secret peut-il tout lire ? *[confiance haute]*
Non : il lui faut aussi le compartiment et la finalité. Le niveau **3** ouvre la classification, pas le besoin d'en connaître.

REPLI 30 SECONDES Deux refus, deux motifs, zéro canari : la protection du secret est observable.

Prononciation : Confidentiel : « con-fi-den-ciel » · canari : « ca-na-ri » · clearance : dire « habilitation ».

NOTES DE SÉANCE

DIAPOSITIVE 13 · P5 · INJECTION **1:10**

Injection neutralisée, chaîne d'audit vérifiée

À DIRE

1. Deuxième démonstration : un bulletin partenaire contient « ignore previous instructions » et demande une exfiltration.
2. Le serveur ne l'exécute pas : il neutralise l'instruction, la signale par un fanion et la livre comme une donnée inerte.
3. La campagne compte **3** charges hostiles neutralisées sur **3**, et zéro faux positif sur **11** contenus bénins.
4. Chaque appel produit une entrée d'audit ; la chaîne SHA-**256** est vérifiée en une commande.
5. Le journal contient **116** entrées pour **115** appels : une entrée supplémentaire trace une erreur de protocole, sans la masquer.

CE QUE ÇA PROUVE	CLAUSE VISÉE
Injection neutralisée et chaîne d'audit valide.	P5 — injection, audit, tests d'abus A10 et A14.

CHORÉGRAPHIE

→ **0–12 s** : lire la phrase hostile affichée, puis marquer le rejet.
→ **12–28 s** : pointer « instruction_inactive » et le fanion.
→ **28–42 s** : montrer **3** sur **3** et zéro faux positif.
→ **42–58 s** : descendre sur la vérification de chaîne.
→ **58–70 s** : montrer **116** entrées et la ligne « résultat : OK ».

QUESTIONS PROBABLES DU JURY

Pourquoi 116 et pas 115 ? *[confiance haute]*
115 appels d'outils attendus, plus une erreur de protocole mal formée que nous avons choisie de journaliser. Nous ne supprimons pas l'entrée gênante : elle prouve que le serveur trace aussi ses propres erreurs.

Peut-on réécrire le journal ? *[confiance moyenne]*
La chaîne détecte une altération locale, car chaque entrée contient l'empreinte de la précédente. Sans ancrage externe, un attaquant qui réécrit toute la chaîne peut tromper un vérificateur local : c'est une limite nommée.

Un filtre par mots-clés suffit-il ? *[confiance haute]*
Non : l'injection est heuristique. Nous neutralisons et signalons, mais nous ne prétendons pas couvrir toutes les formulations. Le jeu de test est limité à trois charges.

REPLI 30 SECONDES L'instruction hostile reste une donnée : elle est neutralisée, signalée et tracée.

Prononciation : SHA-**256** : « esse-ach-a deux cent cinquante-six » · SQLite : « esse-cu-lite » · audit : « au-di ».

NOTES DE SÉANCE

DIAPOSITIVE 14 · P5 · CAMPAGNE **0:55**

31 scénarios, 31 réussites, 12,42 ms

À DIRE

1. La campagne finale comporte **31** scénarios : **15** nominaux ou de durcissement, **16** abus.
2. Résultat : **31** sur **31**, et **16** abus sur **16** maîtrisés.
3. La latence p95 est de **12,42 ms** sur **60** requêtes, avec audit actif, pour une cible de **50 ms**.
4. Une révocation est appliquée en **10 ms** sur la requête suivante.
5. La maquette naïve échoue **8** fois sur **8** sur les mêmes contrôles ; le serveur durci échoue **0** fois.

CE QUE ÇA PROUVE	CLAUSE VISÉE
Campagne complète et métriques mesurées.	P5 — tests nominaux et abus, métriques, avant/après.

CHORÉGRAPHIE

→ **0–10 s** : montrer **31** sur **31** et **16** sur **16**.
→ **10–25 s** : pointer p95 **12,42 ms** et la cible **50 ms**.
→ **25–38 s** : montrer la révocation à **10 ms**.
→ **38–50 s** : passer au **8** vers **0**.
→ **50–55 s** : transition vers les limites.

QUESTIONS PROBABLES DU JURY

Comment mesurez-vous p95 ? *[confiance moyenne]*
Sur **60** appels consécutifs à deux outils, avec audit actif, dans le laboratoire. C'est une mesure locale, pas un banc de charge réseau.

Les tests sont-ils indépendants ? *[confiance haute]*
Le laboratoire est réinitialisé, les jetons sont réémis et chaque profil est relancé. Les scénarios d'abus utilisent de vrais refus, pas des simulations.

Pourquoi 16 abus ? *[confiance haute]*
Pour couvrir les dix risques : fuite, injection, jeton, posture, oracle, débit, audit, fichiers. Chaque abus cite l'exigence qu'il valide.

REPLI 30 SECONDES **31** sur **31**, **16** sur **16**, **12,42 ms** : la campagne est verte, et les chiffres sont dans le JSON.

Prononciation : p95 : « quatre-vingt-quinzième centile » · ms : « millisecondes » · JSON : « jé-sonne ».

NOTES DE SÉANCE

DIAPOSITIVE 15 · LIMITES **0:50**

Huit faiblesses neutralisées, des limites nommées

À DIRE

1. Nous montrons aussi ce que le projet ne prouve pas.
2. L'isolation par espace de noms réseau n'est pas testée ; elle est proposée.
3. L'agent EDR et le chiffrement de disque sont déclaratifs : la posture est un signal, pas une preuve.
4. Le journal est local, sans ancrage externe ; HTTP, OAuth **2.1** et la charge réelle ne sont pas testés.
5. Ces limites ne sont pas des défauts cachés : elles sont dans le rapport, avec la condition qui permettrait de les lever.

CE QUE ÇA PROUVE	CLAUSE VISÉE
8 vers **0** sur les contrôles comparés, et limites explicites.	P5 — limites, note de synthèse, statuts honnêtes.

CHORÉGRAPHIE

→ **0–10 s** : montrer le grand **8** vers **0**.
→ **10–25 s** : balayer la liste des limites.
→ **25–38 s** : insister sur l'ancrage externe absent.
→ **38–48 s** : montrer les statuts proposé, configuré, testé.
→ **48–50 s** : transition vers la conclusion.

QUESTIONS PROBABLES DU JURY

Votre serveur est-il prêt pour la production ? *[confiance haute]*
Non, et nous ne le présentons pas comme tel. C'est un prototype de laboratoire, local, synthétique ; la production demanderait HTTP avec mTLS, OAuth **2.1**, un ancrage d'audit et un agent de posture réel.

Quelle limite est la plus grave ? *[confiance haute]*
L'absence d'ancrage externe du journal : un vérificateur local peut être trompé par une réécriture complète. C'est la première brique à ajouter.

Pourquoi montrer vos faiblesses ? *[confiance haute]*
Parce qu'un jury doit pouvoir distinguer ce qui est testé de ce qui est raconté. Une limite nommée est un travail futur ; une limite cachée est un risque.

REPLI 30 SECONDES Une limite nommée n'est pas un échec caché : c'est un travail futur priorisé.

Prononciation : mTLS : « èm-té-èl-esse » · OAuth : « o-aute » · EDR : « eu-dé-èr ».

NOTES DE SÉANCE

DIAPOSITIVE 16 · CONCLUSION **0:50**

Une politique de secret devenue comportement observable

À DIRE

1. Notre thèse était qu'un serveur MCP peut rester simple, local et honnête tout en rendant la protection du secret démontrable.
2. Nous l'avons prouvé sur trois plans : la décision d'accès, l'étiquetage de sortie et la traçabilité.
3. Les chiffres clés sont **31** sur **31**, **16** sur **16**, **12,42 ms** et **8** faiblesses neutralisées sur **8**.
4. La suite serait un transport HTTP avec mTLS, un ancrage externe du journal et un agent de posture réel.
5. Merci ; nous sommes prêts à répondre à vos questions, et le rapport contient chaque commande pour rejouer les preuves.

CE QUE ÇA PROUVE	CLAUSE VISÉE
Synthèse, contributions et perspectives.	Conclusion et note de synthèse.

CHORÉGRAPHIE

→ **0–12 s** : revenir à la thèse, sans lire.
→ **12–28 s** : pointer les trois plans.
→ **28–42 s** : montrer les quatre chiffres.
→ **42–50 s** : ouvrir sur les perspectives puis remercier.
→ **50 s** : laisser le silence pour les questions.

QUESTIONS PROBABLES DU JURY

Quelle est la valeur ajoutée ? *[confiance haute]*
Nous n'ajoutons pas un outil de plus : nous transformons une politique de secret en comportement observable. Un refus est générique, une réponse est étiquetée, chaque décision est chaînée.

Pourquoi deux matières dans un seul projet ? *[confiance haute]*
La conception et l'exploitation ne sont pas deux projets juxtaposés : la seconde valide les choix de la première, et chaque test renvoie à une exigence.

Que feriez-vous avec plus de temps ? *[confiance haute]*
Trois choses : HTTP avec mTLS, ancrage externe de l'audit et agent de posture réel. Ce sont les limites qui ont le plus d'impact.

REPLI 30 SECONDES Une phrase : nous avons transformé une politique de secret en comportement observable.

Prononciation : mTLS : « èm-té-èl-esse » · MCP : « èm-sé-pé » · audit : « au-di ».

NOTES DE SÉANCE

Plan de secours — version 10 minutes

Si le jury réduit le temps, garder le fil « problème → preuve → limite ». Les diapositives **3**, **5** et **9** se résument en une phrase orale et se sautent sans casser le raisonnement. Le total ci-dessous fait **9 min 30**, laissant **30** secondes de respiration.

#	Diapositive	Secondes	Ce qu'on ne coupe pas
1	Titre et promesse	**30**	les deux validations et le fil rouge
2	Problème et thèse	**40**	le chiffre du problème et la phrase de thèse
4	Menaces et risques	**40**	la matrice et les deux risques majeurs
6	Exigences	**40**	EF de confidentialité et ENF d'audit
7	Comparatif et architecture	**40**	le choix C4 et les trois zones
8	Zones et CP	**60**	CP1, CP2, CP5, CP7 et le journal unique
10	Durcissement	**40**	uid, droits de la base, zéro port
11	Fuite bloquée	**40**	les deux refus et les deux motifs
12	Attaques	**70**	16/16 abus et 3/3 injections
13	Métriques	**50**	8/8 contre 0/8 et la p95
14	Statuts	**50**	testé / configuré / proposé
15	Limites	**40**	les cinq limites assumées
16	Conclusion	**30**	la phrase de clôture

Phrases de transition à ne pas perdre

— Après la diapositive **7** : « La décision est prise ; il reste à prouver qu'elle tient. Khaled prend la suite sur la réalisation. »

— Avant la démonstration : « Je ne raconte pas le contrôle, je le déclenche devant vous. »

— Après la démonstration : « La fuite est bloquée, journalisée et visible : c'est la promesse tenue, pas une intention. »

— Conclusion : « Le secret n'est pas une promesse de politique, c'est une propriété testée ; les limites restantes sont nommées. »

Si un test échoue pendant la soutenance

- Annoncer le statut réel sans improviser : « le test est rejoué maintenant ; s'il échoue, je montre le journal et la correction prévue ».
- Ne jamais masquer une sortie : commenter le code obtenu, puis revenir au résultat déjà consigné dans preuves/logs/tests_latest.json.
- Si la machine ne répond plus, basculer sur les captures **01** à **07** de preuves/captures_ecran : elles portent l'horodatage et le numéro de commande.

Fin du conducteur · 16 diapositives · dossier preuves/ joint sur clé USB